Unit 2- Q1 - Identify key concepts of cyber threat intelligence

Note:

You should be aware of the difference between the terms cyber threat and threat:

• cyber threat = phishing, etc

• threat = at risk.

Cyber Threat Intelligence (CTI) is information about cyber threats that is collected, analyses and used to help an organisation understand and protect itself against cyber-attacks. It can help an organisation identify potential threats, understand how attackers operate, and make better security decisions.

Cyber threat a malicious activity or attack that could cause harm to a computer system, network, device or data. Examples include phishing malware, ransomware, DoS attacks, and data breach.
Threat a situation or event that could cause harm or put an organization system or individual at risk. A threat does not necessarily mean that an attack has happened, but it means there is a chance of harm occurring

Unit 2- Q2 - Explain the following terms in relation to cyber security:

a) threats

b) exploits

c) vulnerabilities

d) risk

Note:

Threats include, but are not limited to:

• malicious software, data breaches, Denial of Service (DoS) attacks

Vulnerabilities must include, but are not limited to flaws, features, user errors, and zero day.

A threat is anything that has the potential to cause harm to a computer system, network, device, or data. A threat may try to seal information, damage systems, interrupt service, or gain unauthorized access.

Example

Malicious software- software designed to damage the system, steal information, or gain unauthorized access. For example, viruses, ransomware, and spyware.

Data breach- when confidential or sensitive information is accessed stolen or disclosed without permission

Denial of Service Attacks- an attack that attempts to make a system or service unavailable by overwhelming it with requests or traffic

An exploit is a method, technique, or piece of code that takes advantage of a vulnerability in a computer system, application networking or device.

Exploits can be used to steal data install malware change information or gain control of systems

A vulnerability is a weakness or flaw that could be used by a threat to compromise the security of a system network application or device.

Can occur in multiple ways

Flaws- mistakes or weaknesses in software or system design that could be exploited.

Features- legitimate features of a system that could potently be misused by an attacker.

User errors- made by users such as weak passwords, clicking malicious links or accidentally sharing confidential information.

Risk is the possibility that a threat will take advantage of a vulnerability and cause harm or loss to an organization system or individual

Risk can involve both the likelihood of an incident occurring and the impact if it happens.

For example, if a company has an unpatched server containing sensitive customer information, there is a risk that an attacker could exploit vulnerability and steal the data.

Unit 2- Q3 - Describe the threat intelligence lifecycle

The Threat intelligence lifecycle is a continues process used by cyber security people to identify, collect, and analyze info about cyber threats and turn it into useful intel for decision making.

There are 6 main stages:

Planning & Direction- Cyber security professionals determine what type of threat intel is needed to prevent and respond to cyberattacks. They identified the company's intel requirements and decided what info needs to be collected.

Collection- Info about current and future threats is collected from different sources. These include internal logs, records, technical sources, and info from deep web or dark web.

Processing- The raw info that has been collected is processed into a format that can be analyses more easily. This could include company info into spread sheets, decrypting flies, translating info, and checking if the info is correct.

Analysis- The **Processed** info is examined to identify threats and determine whether a company's systems may have been compromised. For example, security professionals may look for evidence of unauthorized access or suspicious emails attachments being opened.

Dissemination- The result of **Analysis** is turned into a threat intel report and given to the people responsible for making the decisions, such as senior management or the CEO. The info needs to be presented in a suitable way, including deciding how much technical detail should be included.

Feedback- The decision maker reviews intel report and decides what action to take. They also provide feedback about whether the intel answered their requirements and whether the company's intel requirements need to be changed.

Unit 2- Q4 - Describe how to find out about emerging attack techniques and how to recognize them

Cyber security professionals need continuously monitoring new and emerging attack tequniqes because attackers regally develop different ways of compromising systems. One way of doing this is by collecting info from several different sources.

Indicators of compromise can help identify attackers that may already be taking place. IoC are signs of unusual or suspicious activity such as unexpected network traffic, unusual changes to flies or systems, or large amounts of data being moved.

Deep web can also provide info about emerging threats some private forums and communities are used by cyber criminals to discuss hacking tools vulnerabilities and malware. Mongering these areas can give security professionals an idea of new techniques that attackers may be developing.

The deep web is another source of threat intel criminals may use anonymous services and marketplace to trade stolen info, hacking tools, and other services. Security teams monitor these sources to find out whether a company info has been stolen or whether new attackers' tools are being offered.

Unit 2- Q5 - Consider what could be included in Open-Source Intelligence data sets

Note:

(Open-Source Intelligence is also known as OSINT)
Websites->information published on a company website, blog and forms

social media->publicly available posts, profiles, comments and discussion

news articles->information about cyber-attacks, crime, new technology and other stuff

public record->government records, company registry and other publicly document

technical info->IP addresses, domain name, DNS records, and info about networks

Job adverts->these can sometimes reveal info about company tech, software, and infrastructure

Unit 2- Q6 - Explain why it is important to only use reliable and valid sources of Open-Source Intelligence information

Accuracy reliable sources more likely to provide to provide correct and up to date information.

Avoids misinformation unreliable website or social media posts may contain false info

Better decision making cyber professional and news agencies need accurate info

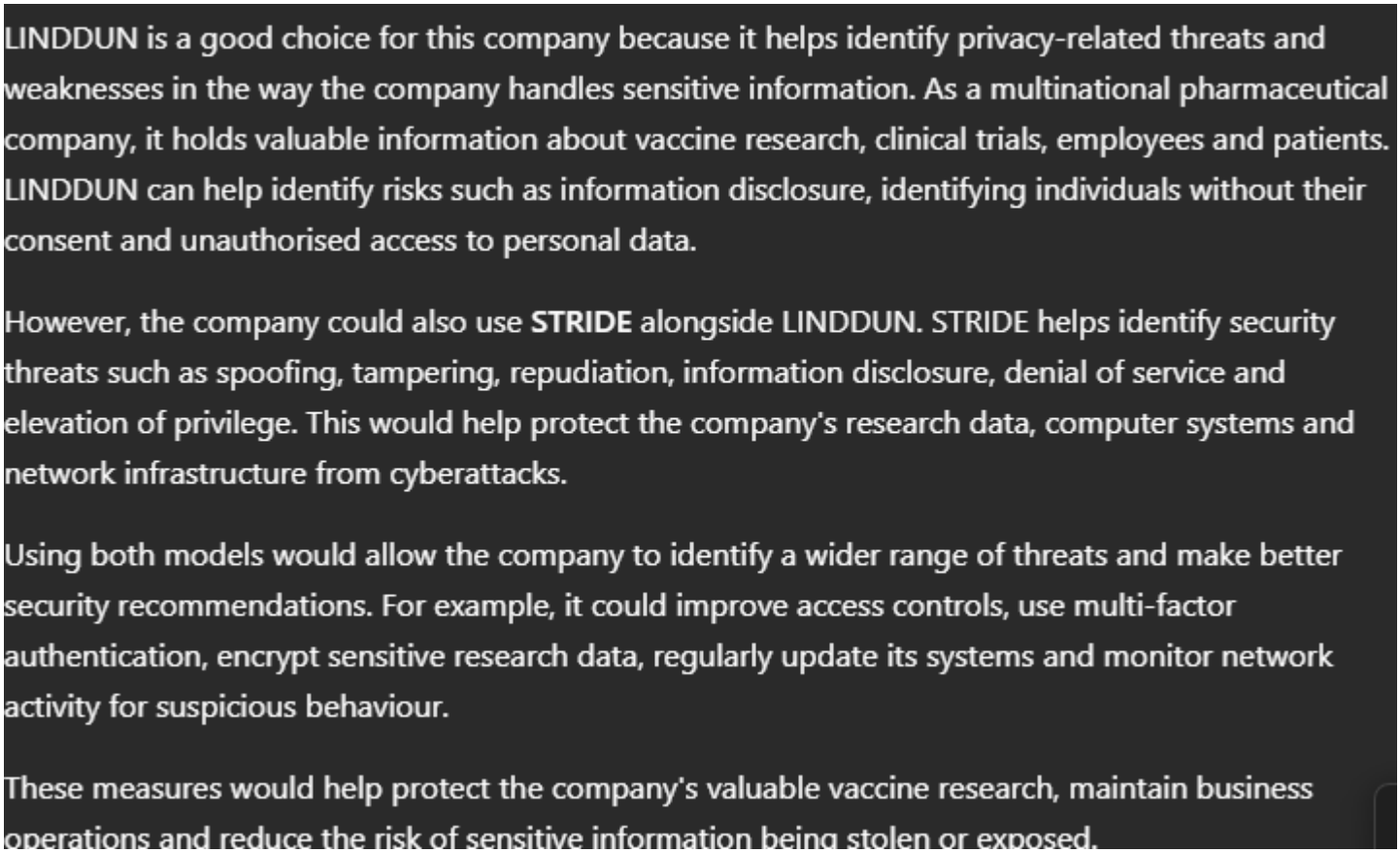
Legal & ethical considerations info should come from legitimate publicly available source

Unit 2- Q7 - Explain the importance of using reliable sources of information in relation to cyber security threats

Unit 2- Q8 - Consider the current threat status and make possible recommendations based upon cyber threat intelligence information

NOTE: You could create a case study based on the information gathered, including recommended actions.

Imagin that you are working for a multy-national pharmaceutical company that makes and tests vaccines for different diseases. The company has thousands of employees who all work in one of the company's offices. The company has regular security training for its employees and a very expensive cyber security team who have been working together for many years.
What type of threat model or models might be a good choice for this company to use and why?
LINDDUN is a good choice for them to use because it helps identify privacy-related threats and weaknesses in the way the company handles sensitive info. However, the company could also use STRIDE alongside LINDDUN as STRIDE helps identify security threats such as spoothing, tampering, repudiation, information disclosure, DOS, and elevation of privilege.


LINDDUN is a good choice for this company because it helps identify privacy-related threats and weaknesses in the way the company handles sensitive information. As a multinational pharmaceutical company, it holds valuable information about vaccine research, clinical trials, employees and patients. LINDDUN can help identify risks such as information disclosure, identifying individuals without their consent and unauthorised access to personal data.

However, the company could also use **STRIDE** alongside LINDDUN. STRIDE helps identify security threats such as spoofing, tampering, repudiation, information disclosure, denial of service and elevation of privilege. This would help protect the company's research data, computer systems and network infrastructure from cyberattacks.

Using both models would allow the company to identify a wider range of threats and make better security recommendations. For example, it could improve access controls, use multi-factor authentication, encrypt sensitive research data, regularly update its systems and monitor network activity for suspicious behaviour.

These measures would help protect the company's valuable vaccine research, maintain business operations and reduce the risk of sensitive information being stolen or exposed.

Unit 2- Q9 - Analyse relevant cyber threat intelligence information requirements for an organisation

NOTE:

You must cover information on at least four different types of attack; a business to consumer (B2C) business is easier to focus on. Types of attack could include:

• phishing • ransomware • Denial of Service (DoS)/Distributed Denial of Service (DDoS) • virus.

A business-to-consumer (B2C) company that sells products online needs to gather cyber threat intelligence to protect its customers, employees, payment systems and business operations. This will help the company understand current and emerging threats, identify weaknesses, and decide what security measures to put in place.

- **Phishing** criminals send fraudulent emails/ messages pretending to be a trusted organization. Their aim is to trick people into handing over sensitive info. Company needs cyber threat intel about Phishing campaigns, common techniques used by attacker & suspicious emails/ website. This info can help the company recognize Phishing attempts and warn employees and consumers.
- **Ransomware** is software that encrypts files or locks system and demands payment to restore access. An attacker could prevent online retailer from accessing customer info, processing order or operation its website. The companies need info about ransomware threats, so it knows the methods attackers use to gain access and the vulnerabilities they exploit. This will help them by keeping them informed of cyber threats.
- **Denial of Service (DoS)/Distributed Denial of Service (DDoS)** a DoS attack attempts to overwhelm a server with traffic, preventing legitimate users from accessing a service. A DDoS attack uses multiple systems to generate traffic to make the attack more difficult to manage. For an online company, this makes its website unavailable, preventing customers from making purchases and causing financial loss.
- **Virus** is a computer type of malicious software that can attach itself to files or program and spread when they are executed. Viruses can damage files, disrupt computer systems, and potentially expose sensitive info. The company needs cyber intel about newly discovered viruses, known malware signatures, infection methods, and vulnerable software. This info can help its security team update antivirus software, apply security patches and identify infected devices before problems spread.

Unit 2- Q10 - Describe a range of threat models

NOTE:

You must **describe** a minimum of three threat models. These could include, but are not limited to:

• STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) • PASTA (Process for Attack Simulation and Threat Analysis) • LINDDUN (Linkability, Identifiability, Non-repudiation, Detectability, Disclosure of information, Unawareness, Non-compliance) • CVSS (Common Vulnerability Scoring System) • Attack Trees.

STRIDE is a threat modeling framework developed by Microsoft it identifies six categories of security threats that could affect a system those are:

- **Spoofing**- When an attacker pretends to be a legitimate user or device to gain unauthorized access. For example, stealing someone's login details to access their account.
- **Tampering** – When an attacker makes unauthorized changes to data or software. For example, modifying information stored in a company database.
- **Repudiation** –When a user or attacker denies performing an action, making it difficult to prove what happened. For example, someone deleting important files and denying responsibility.
- **Information Disclosure** – When confidential or sensitive info is exposed to unauthorized people. For example, hackers steal customer details from a database.

- **DOS –** When attackers overwhelm a system with traffic or requests, preventing litigating users from accessing It.
- **Elevation of Privilege** – When an attacker gains higher permissions then they are supposed to have.

PASTA stands for Process for Attacker Simulation and threats Analysis. It is a risk-based threat modeling framework that focuses on understanding how attackers could target a system and the potential business impact of an attack.
PASTA uses 7 steps:

- **Define business objectives** – Identify the company's goals for important assets and security requirements.
- **Define the technical scope** – Identify the system applications network and infrastructure that need protection.
- **Application decomposition** – Brake down the system to understand how data flows where it is stored and how different components communicate.
- **Threat analysis** – Identify potential attackers their motivations and the threats they could create.
- **Vulnerability analysis** – Examine the system for weaknesses that attackers could exploit.
- **Attacker Modelling** – simulate possible attacker methods to understand how attackers might compromise the system.
- **Risk and Impact analysis –** Evaluate the likelihood and potential consequences of attacks and decide which security measures should be prioritised.

For example, a bank could use PASTA to analyses the risks of its online banking system to identify possible attacks methods and prioritized.

LINDDUN is a privacy focused threat molding framework. It is designed to identify threats that could compromise people's privacy and the way their personal info is collected, scored, and processed.
LINDDUN uses 7 categories:

- **Linkability**: When info from different sources can be connected to identify or track an individual.
- **Identifiability**: When an individual can be identified from information that should be anonymous or protected.
- **Non-repudiation**: When a system creates evidence that links an individual to action potentially affecting their privacy.
- **Detectability**: When an attacker can determine whether certain information or activities exist even without accessing the actual data.
- **Disclosure of information**: When personal or sensitive info is exposed to unauthorised individuals.
- **Unawareness**: When users are unaware of how their personal info is collected, stored, or used.
- **Non-compliance**: When the company fails to follow privacy laws, regulations or policies.

For example, a healthcare company could use LINDDUN to assess a patient's records system identifying risk such as unauthorised access to medical info or the collection of personal data without proper user awareness.

Unit 2- Q11 - Explain the steps within a threat model

- The first step is **Identify & define the system**-> applications or network that needs protecting. This includes understanding its purpose, the data it handles, and the different components involved.
- **Identify valuable assets**-> the important info & resource that need protecting such as customer info passwords, finance records, database, and network infrastructure. Helps determine what attackers may want.

- **Identify potential threats** -> possible threats could affect the system. These could include hackers, malware, phishing attackers, insider threats, and denial of service attack. Frameworks like STRIDE can help identify different categories of threats.
- **Identify vulnerabilities**-> Exain the system to find weakness that could exploit. Examples include weak passwords, outdated software, unpatched security flaws, and incorrect config firewalls.
- **Analyse and assess risk** -> Evaluate each threat by considering how likely it is to happen and how much damage it could cause.

Identify & implement security controls-> Chose appropriate security measures to reduce the risk. These could include multy-factor authentication firewalls encryption regular software updates, access controls and staff training.

- **Review and update the threat model**-> threat modelling is an ongoing process. Companies should regularly review their threat models, especially when introducing new technology changing systems or discoing new vulnerability.

Unit 2- Q12 - Evaluate a threat model

Advantages of STRIDE:

- Identifies a wide range of threats coves 6 different categories of security threats, helping companies identify weakness they might otherwise overlook.
- Easy to understand its 6 categories provide a clear structure that security teams can use to identify and discuss potential threats.
- Improves security planning by identifying possible attacks by early companies can introduce security controls such as encryption, access restriction, and authentication.

Disadvantage of STRIDE:

- Does not priorities risk by itself STRIDE identifies threats but does not automatically determine which threats are most likely or which could cause the greatest damage.
- Requires technical knowledges security teams need to understand how systems work to identify relevant threats accurately.
- Needs regular updates on new vulnerabilities technologies and attack methods can make an existing threat model less effective if it is not reviewed.

STRIDE is a useful threat modelling framework because it provides a structured way to identify different types of cyber security threats. It is particularly valuable during system design and development as it helps companies recognize security weakness before attackers exploit them.

Unit 2- Q13 - Identify at least 3 types of malicious software and describe the effects of different types of malicious software on an infected system.

Malicious software includes, but is not limited to:

• virus • spyware • trojan • worms.

Virus: attaches to executable files or documents and spread when these files are opened or executed.

Effect: they can corrupt or delete files cause system crashes to slow down performance and consume cup or memory.

Worms: self-replicating malware that spreads across networks without user interaction exploiting software vulnerabilities.

Effect: they cause network congestion slow system performance and propagate rapidly potentially leading to widespread systems or networks.

Ransomware: encrypts fields or locks system demanding payment for access restored.

Effect: victims loss access to critical data halt business operations and face financial losses.

Trojan: disguise themselves as legitimate software to trick users into installation.

Effect: once installed they can steal sensitive data Provie remote access to attackers or deliver additional malware compromising systems security and privacy.

Unit 2- Q14 -Describe the motives for using specific malicious software attacks

Virus: a virus may be used by attackers for serval different motivations. These include **stealing data, making money, disrupting computer/ network systems, gaining unauthorized access, spying on individuals or companies, or seeking revenge.** Can be used to damage or disrupt a company's operations.

Worm: a worm be used to **steel data, make money, or disrupt systems & business operations**. Because worms spread automatically between computer systems and networks attacker may use them to create a bot net

Trojan: can be used to gain unauthorized access to computer systems whilst appearing to be legitimate software. The motivations can include **money, stealing information, spying, political, and revenge.**

Ransomware: motivation is often financial gain. Attackers target companies to encrypt their files or systems and demand payment. Can also be used to **disrupt operations and create fear** or pressure on an organization to pay.

Spyware: steal info such as **credit card numbers, banking info, login credentials** which can be sold on the black market, used to commit fraud persistent watching.

Unit 2- Q15 - Identify how specific malicious software attacks are made more effective due to human factors.
Become more effective when attackers exploit human traits such as trust, fear, carelessness, biases and lack of cybersecurity awareness.

Human factors:

Emotions like trust, fear, helpfulness-> attackers often design malware delivery methods that manipulate emotions.

Phishing emails that appear authentic or urgent to exploit human trust and fear.

Curiosity and impulse

USB based attacks rely on users' curiosity, e.g. plugging in an unknow USB stick in a public place.

lack of cybersecurity awareness-> Users unaware of threats are more likely to fall for them.

Unit 2- Q16 - Explain the term 'social engineering'

Social engineering is a type of cyber-attack in which criminals manipulated or tricked people into revealing confidential info, giving unauthorised access to systems or caring out actions that compromise security.

Instead of relying on technical methods to brick into systems, social engineers exploit human behavior such as trust fear curiosity or sense of urgency.

Examples:

Phishing sending fake emails or messages that appear to come from trusted companies to trick people into clicking malicious links or revealing password and personal info.

Unit 2- Q17 - Give examples of how Open-Source Intelligence can be used for social engineering

Open-Source Intelligence is the process of collecting and analyzing publicly available info from sources such as social media, websites, search engines, and public records.

Examples of **OSI**

- **Social media Research:** use platforms such as Facebook, Instagram, and LinkedIn to find personal info including people's names, workplace interests and relationships.
- **Employee & company research:** Use company website and LinkedIn to identify employees their jobs roles and company structure.
- **Email address discovery:** can use company websites, public directories and other online sources to find employee email addresses. They can use these addresses to send targeted phishing emails that appear to be legitimate business communications.

Unit 2- Q18 - Describe ways a social engineering attack could take place

Social engineering is a type of cyber-attack where criminals manipulate people into revealing confidential info.

- Phishing: involves sending fake emails or messages that appear to come from trusted companies to trick people into clicking malicious links or revealing password and personal info.
- **Tailgating:** occurs when an unauthorized person follows an authorized employee into a restricted area without using their own access credentials. For example, an attacker could pretend to be a delivery driver carrying packages and following an employee through a secure entrance.
- Baiting involves offering something attractive to encourage a victim to perform an action that compromises their security. For example, an attacker could send an email to an employee telling them that they've won 10,000£ and need to click the link to collect it so they click the link and enter personal details.